

Vulnerability Assessment Report

15th MAY 2026

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 2026 to August 2026. NIST SP 800-30 Rev. 1 is used to guide the risk analysis of the information system.

Purpose

The purpose of this vulnerability assessment is to evaluate the risks associated with the company’s publicly accessible database server and decide how these risks could affect business operations. The database supports employees working remotely and stores information important to daily business activities. Because the server has remained publicly accessible since the company launched, unauthorised users may be able to access or disrupt sensitive information. A compromise or outage affecting this system could interrupt business operations, expose company data, and damage customer trust and organisational reputation.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Hacker	Obtain sensitive information via exfiltration	3	3	9

<i>Employee</i>	<i>Disrupt mission-critical operations</i>	2	3	6
<i>Customer</i>	<i>Alter/Delete critical information</i>	1	3	3

These threat sources and events are based on the NIST guidance provided for publicly accessible systems

Approach

This assessment focused on risks associated with a database server that remains publicly accessible through the internet. Public exposure increases the attack surface and increases the likelihood of unauthorised access attempts or misuse. The selected threat sources and events were chosen because they represent realistic risks to an internet-facing database having business information used by remote employees. Both international attacks and operational failures were considered because each could negatively affect confidentiality, integrity, and availability of the system and disrupt business operations.

Remediation Strategy

The organisation should implement stronger access controls to reduce exposure and limit unauthorised access to the database server. Security improvements should include multi-factor authentication, role-based access controls, and use of the principle of least privilege to make sure employees only access necessary information. The company should replace broad public access with IP allow-listing or secure remote access methods and keep detailed logging and auditing through an Authentication, Authorisation, and Accounting framework. Defense-in-depth controls, including updated encryption and monitoring systems, would further reduce risk and improve incident detection.